



Threat landscape

12 categories

Category	Top 3 controls (plain language)
Compromises to IP	
QoS deviations	
Espionage/trespass	
Forces of nature	
Human error	
Extortion	
Sabotage	
Software attacks	
Hardware failure	
Software failure	
Obsolescence	
Theft	

12 threats with top 3 controls

Category	Top 3 controls (plain language)
Compromises to IP	Limit who can access; label and log sharing; ban secrets into public AI
QoS deviations	Have offline fallback; keep backups; keep a simple comms plan
Espionage/trespass	MFA everywhere; remove old accounts; verify unusual requests
Forces of nature	Offsite backups; practise restore; protect equipment (fire/flood)
Human error	Safe defaults; two-person check for high-risk actions; no-blame reporting
Extortion	Offline/immutable backups; incident plan; practise first-hour checklist
Sabotage	Limit admin rights; log actions; ability to rebuild/restore fast
Software attacks	Update promptly; email/attachment caution; report quickly
Hardware failure	Backups + spares; monitoring; clear asset ownership
Software failure	Test and stage changes; rollback plan; change records
Obsolescence	Asset inventory; isolate legacy; funded upgrade plan
Theft	Encrypt devices; remote wipe; report immediately

Threat standards/frameworks

Threat category	Primary standards/frameworks (typical)	Example plain-language controls	Complexity
Compromises to IP			
QoS deviations			
Espionage/trespass			
Forces of nature			
Human error			
Information extortion			
Sabotage/vandalism			
Software attacks			
Hardware failures			
Software failures			
Obsolescence			
Theft			

Threat standards/frameworks

Threat category	Primary standards/frameworks (typical)	Example plain-language controls	Complexity
Compromises to IP	ISO/IEC 27001/27002; NIST CSF/SP 800-53; CIS Controls	“Need-to-know” access; sharing approvals; activity logging	High
QoS deviations	NIST SP 800-34; ISO/NIST governance baselines	Offline fallback; backups; supplier expectations	Medium
Espionage/trespass	ISO/IEC 27001; NIST SP 800-53; CIS Controls	MFA; remove old accounts; access reviews	High
Forces of nature	NIST SP 800-34; GDPR security principle (if personal data)	Offsite backups; restore practice; building protections	Medium
Human error	NIST SP 800-53; CIS Controls	Safe defaults; two-person checks; simple reporting	Medium
Information extortion	CISA #StopRansomware; NIST SP 800-61; (GDPR if personal data)	Immutable backups; first-hour plan; comms templates	High
Sabotage/vandalism	NIST SP 800-53; ISO/IEC 27001	Limit privileges; log actions; rebuild/restore capability	High
Software attacks	CIS Controls; ENISA threat landscape context	Patch quickly; cautious attachments; report early	Medium
Hardware failures	NIST SP 800-34	Backups; spares; monitoring	Medium
Software failures	NIST SSDF; NIST SP 800-53 (general control catalogue)	Test changes; rollback plans; change records	High
Obsolescence	ISO/IEC 27001; NIST CSF	Inventory; isolate legacy; funded upgrade plan	High
Theft	GDPR Art. 32/ICO security guidance (if personal data); ISO/NIST/CIS baselines	Encrypt; remote wipe; rapid reporting	Low